Penetration Test Report: Hammer Web Application Case Study

1) Executive Summary

The security assesment conducted on the Hammer Web Application (hammer.thm, 10.80.156.131:1337[The IP Address could change]) has uncovered multiple critical vulnerability, including Information Disclosures, Broken Authentication (OTP Bypass), & JWT Secret Forgery. Because of these flaws, an unauthenticated attacker will be allowed to gain full administrative control & execute arbitrary commands on the underlying server.

2) Risk Rating

Vulnerability	Severity	Impact
Broken Authentication (OTP Brute Force)	Critical	High
JWT kid Path Traversal	Critical	High
Information Disclosure (Dev Notes/Logs)	Medium	Low

3) Vulnerability Details

3.1) Information Disclosure (Directory Naming Convention)

Description: Developer comments in the html page source code revealed a specific directory naming convention (hmr_).

Impact: Allowed for targeted directory brute-forcing, which lead to the discovery of sensitive log files & hidden endpoints.

Evidence: <!-- Dev Note: Directory naming convention must be hmr_DIRECTORY_NAME -->

3.2) Broken Authentication (OTP Bypass via IP Spoofing)

Description: The password reset mechanism utilized a 4-digit OTP. While rate-limiting was present, it relied on the client's IP address, which was easily bypassed using the X-Forwarded-For HTTP header.

Exploitation: Used ffuf to brute force a 10,000 combination (OTP Bypass) while rotating 'X-Forwarded-For' header to aviod lock-out.

Tooling: ffuf -u [URL] -d "recovery_code=FUZZ" -H "X-Forwarded-For: FUZZ"

3.3) Remote Code Execution (JWT Forgery via kid Parameter)

Description: The application used JSON Web Tokens (JWT) for session management. The kid (Key ID) header was vulnerable to Path Traversal, allowing the server to use an arbitrary local file as the signing secret.

Exploitation:

1) Located a public .key file (188ade1.key) in the web root.

2) Modified the JWT header kid to point to /var/www/html/188ade1.key.

3) Modified the JWT payload role to admin.

4) Signed the token using the plaintext content of the discovered key.

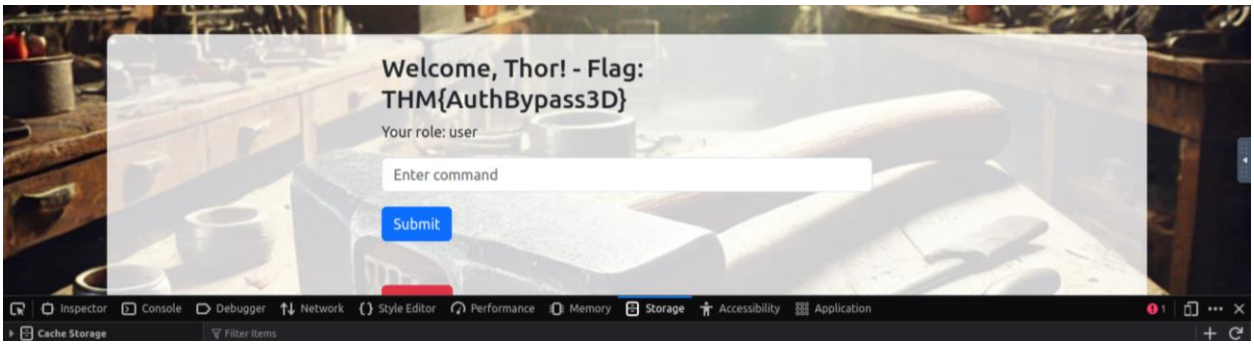
Impact: Full Administrative access to the '/execute_command.php' endpoint.

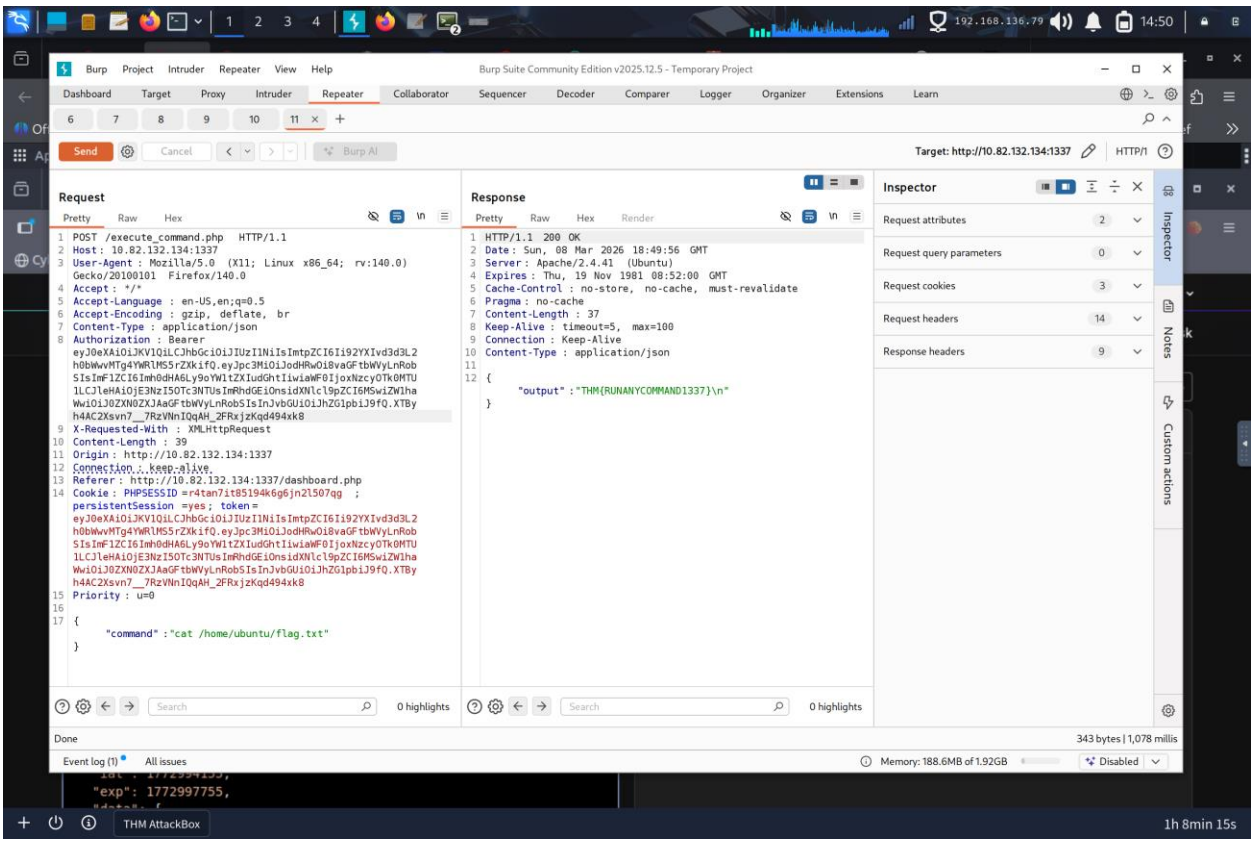
4) Findings & Evidence

User Flag: THM{AuthBypass3D}

Root/System Flag: THM{RUNANYCOMMAND1337}

Proof of Concept:





5) Remediation Recommendations

1) Secure JWT Implementation: Hardcode the signing secret in the backend configuration; do not allow the kid header to reference local file paths.

2) Robust Rate Limiting: Implement rate-limiting based on account username or session ID, not just IP address.

3) OTP Complexity: Increase the One-Time Password complexity to 6+ alphanumeric characters and implement a strict "three strikes" lockout.

4) Information Leakage: Remove all developer notes and ensure sensitive logs (/hmr_logs) are not web-accessible.